

Application Security Verification Standard

Kebsi Nozha
ISG-2022



V2 Authentication

Objectif de contrôle

L'authentification est l'acte qui consiste à établir ou à confirmer qu'une personne (ou quelque chose) est authentique et que les affirmations faites par une personne ou au sujet d'un dispositif sont correctes, résistantes à l'usurpation d'identité et empêchent la récupération ou l'interception des mots de passe.

Lorsque l'ASVS a été publiée pour la première fois, le nom d'utilisateur + mot de passe était la forme d'authentification la plus courante en dehors des systèmes de haute sécurité. L'authentification à facteurs multiples (MFA) était communément acceptée dans les cercles de sécurité mais rarement requise ailleurs. Avec l'augmentation du nombre de brèches de mots de passe, l'idée que les noms d'utilisateur sont en quelque sorte confidentiels et les mots de passe inconnus, a rendu de nombreux contrôles de sécurité inefficaces.

Objectif de contrôle

NIST 800-63 - Norme d'authentification moderne et fondée sur des preuves

NIST 800-63b est une norme moderne, basée sur des preuves, et représente le meilleur conseil disponible, indépendamment de son applicabilité. La norme est utile à toutes les organisations du monde entier, mais elle est particulièrement pertinente pour les agences américaines et celles qui traitent avec des agences américaines.

La terminologie de la norme NIST 800-63 peut être un peu déroutante au début, surtout si vous n'êtes habitué qu'à l'authentification par nom d'utilisateur + mot de passe. Des progrès en matière d'authentification moderne sont nécessaires, nous devons donc introduire une terminologie qui deviendra courante à l'avenir, mais nous comprenons la difficulté de compréhension jusqu'à ce que l'industrie s'habitue à ces nouveaux termes. Nous avons fourni un glossaire à la fin de ce chapitre pour vous aider. Nous avons reformulé de nombreuses exigences afin de satisfaire l'intention, plutôt que sa forme. Par exemple, l'ASVS utilise le terme "mot de passe" alors que le NIST utilise "secret mémorisé" tout au long de cette norme.

Objectif de contrôle

Les applications peuvent toujours dépasser les exigences du niveau actuel, surtout si l'authentification moderne figure sur la feuille de route d'une application. Auparavant, l'ASVS exigeait une AMF obligatoire. Le NIST n'exige pas de MFA obligatoire. C'est pourquoi nous avons utilisé une désignation optionnelle dans ce chapitre pour indiquer les cas où l'ASVS encourage mais n'exige pas de contrôle. Les clés suivantes sont utilisées tout au long de cette norme :

Marque	Description
	Non requis
o	Recommandé, mais pas obligatoire
✓	Obligatoire

V2.1 Exigences en matière de sécurité des mots de passe

Les mots de passe, appelés "Memorized Secrets" par NIST 800-63, comprennent les mots de passe, les codes PIN, les motifs de déverrouillage (unlock patterns) et les phrases de passe. Ils sont généralement considérés comme "quelque chose que vous savez" et sont souvent utilisés comme des authenticateurs à facteur unique. L'utilisation continue de l'authentification à un facteur unique pose des problèmes importants, notamment les milliards de noms d'utilisateur et de mots de passe valides divulgués sur l'internet, les mots de passe par défaut ou faibles, les tables arc-en-ciel et les dictionnaires ordonnés des mots de passe les plus courants.

Les applications devraient fortement encourager les utilisateurs à s'inscrire à l'authentification multi-facteurs, et devraient permettre aux utilisateurs de réutiliser les jetons qu'ils possèdent déjà, tels que les jetons FIDO (jeton USB) ou U2F, ou de se relier à un fournisseur de services d'accréditation qui fournit une authentification multi-facteurs.

V2.1 Exigences en matière de sécurité des mots de passe

#	Description	L1	L2	L3	CWE	NIST §
2.1.1	Vérifiez que les mots de passe définis par l'utilisateur comportent au moins 12 caractères (après avoir combiné plusieurs espaces). (C6)	✓	✓	✓	521	5.1.1.2
2.1.2	Vérifiez que les mots de passe de 64 caractères ou plus sont autorisés, mais pas au delà de 128 caractères. (C6)	✓	✓	✓	521	5.1.1.2
2.1.3	Vérifiez que le mot de passe n'est pas tronqué. Toutefois, des espaces multiples consécutifs peuvent être remplacés par un seul espace. (C6)	✓	✓	✓	521	5.1.1.2
2.1.4	Vérifiez que tout caractère Unicode imprimable, y compris les caractères neutres comme les espaces et les Emojis, sont autorisés dans les mots de passe.	✓	✓	✓	521	5.1.1.2
2.1.5	Vérifier que les utilisateurs peuvent changer leur mot de passe.	✓	✓	✓	620	5.1.1.2
2.1.6	Vérifiez que la fonctionnalité de changement de mot de passe nécessite le mot de passe actuel et le nouveau mot de passe de l'utilisateur.	✓	✓	✓	620	5.1.1.2

V2.1 Exigences en matière de sécurité des mots de passe

#	Description	L1	L2	L3	CWE	NIST §
2.1.7	Vérifiez que les mots de passe soumis lors de l'enregistrement du compte, de la connexion et du changement de mot de passe sont comparés à un ensemble de mots de passe violés, soit localement (comme les 1 000 ou 10 000 mots de passe les plus courants qui correspondent à la politique de mot de passe du système), soit en utilisant une API externe. En cas d'utilisation d'une API, une preuve de connaissance nulle ou un autre mécanisme doit être utilisé pour garantir que le mot de passe en texte clair n'est pas envoyé ou utilisé pour vérifier l'état de violation du mot de passe. Si le mot de passe est violé, l'application doit demander à l'utilisateur de définir un nouveau mot de passe non violé. (C6)	✓	✓	✓	521	5.1.1.2
2.1.8	Vérifiez qu'un compteur de force de mot de passe est fourni pour aider les utilisateurs à définir un mot de passe plus fort.	✓	✓	✓	521	5.1.1.2
2.1.9	Vérifiez qu'il n'existe pas de règles de composition des mots de passe limitant le type de caractères autorisés. Il ne doit pas y avoir restrictions sur l'utilisation de majuscules ou de minuscules, de chiffres ou de caractères spéciaux. (C6)	✓	✓	✓	521	5.1.1.2
2.1.10	Vérifiez qu'il n'y a pas d'exigences en matière de rotation périodique des mots de passe ou d'historique des mots de passe.	✓	✓	✓	263	5.1.1.2
2.1.11	Vérifiez que la fonction "coller", les aides de mot de passe du navigateur et les gestionnaires de mots de passe externes sont autorisés.	✓	✓	✓	521	5.1.1.2
2.1.12	Vérifiez que l'utilisateur peut choisir soit de visualiser temporairement la totalité du mot de passe masqué, soit de visualiser temporairement le dernier caractère tapé du mot de passe sur les plateformes qui n'ont pas cette fonctionnalité en natif.	✓	✓	✓	521	5.1.1.2

V2.2 Exigences générales relatives aux authentificateurs

#	Description	L1	L2	L3	CWE	NIST §
2.2.1	Vérifiez que les contrôles anti-automatisation sont efficaces pour atténuer les attaques par violation des tests d'accréditation, par énumération exhaustive (brute-force) et par verrouillage de compte. Ces contrôles comprennent le blocage des mots de passe les plus courants, les verrouillages progressifs, la limitation de débit, les CAPTCHA, les délais toujours plus longs entre les tentatives, les restrictions d'adresse IP ou les restrictions basées sur le risque telles que l'emplacement, la première connexion sur un appareil, les tentatives récentes de déverrouillage du compte, ou autres. Vérifiez qu'il n'y a pas plus de 100 tentatives infructueuses par heure sur un seul compte.	✓	✓	✓	307	5.2.2 / 5.1.1.2 / 5.1.4.2 / 5.1.5.2
2.2.2	Vérifier que l'utilisation d'authentificateurs faibles (tels que les SMS et les e-mails) se limite à la vérification secondaire et à l'approbation des transactions et ne remplace pas les méthodes d'authentification plus sûres. Vérifiez que les méthodes plus fortes sont proposées avant les méthodes faibles, que les utilisateurs sont conscients des risques, ou que des mesures appropriées sont en place pour limiter les risques de compromission du compte.	✓	✓	✓	304	5.2.10
2.2.3	Vérifier que des notifications sécurisées sont envoyées aux utilisateurs après la mise à jour des détails d'authentification, tels que la réinitialisation de l'identifiant, le changement d'adresse électronique ou d'adresse, la connexion à partir d'un lieu inconnu ou risqué. L'utilisation de notifications "push" - plutôt que de SMS ou d'e-mail - est préférable, mais en l'absence de notifications "push", les SMS ou les e-mails sont acceptables tant qu'aucune information sensible n'est divulguée dans la notification.	✓	✓	✓	620	

V2.2 Exigences générales relatives aux authentificateurs

2.2.4	Vérifier la résistance à l'usurpation d'identité contre le phishing, comme l'utilisation de l'authentification multi-facteurs, les dispositifs cryptographiques avec intention (comme les clés connectées avec un "push to authenticate"), ou à des niveaux AAL supérieurs, les certificats côté client.	✓	308	5.2.5
2.2.5	Vérifier que lorsqu'un fournisseur de services d'accréditation (CSP) et l'application vérifiant l'authentification sont séparés, un TLS mutuellement authentifié est en place entre les deux points terminaux.	✓	319	5.2.6
2.2.6	Vérifier la résistance au attaque de rejeu par l'utilisation obligatoire de dispositifs OTP, d'authentificateurs cryptographiques ou de codes de consultation.	✓	308	5.2.8
2.2.7	Vérifier l'intention d'authentification en exigeant l'entrée d'un jeton OTP ou une action initiée par l'utilisateur telle qu'une pression sur un bouton d'une clé matérielle FIDO.	✓	308	5.2.9

V2.3 Exigences relatives au cycle de vie des authenticateurs

Les authenticateurs sont les mots de passe, les jetons logiciels, les jetons matériels et les dispositifs biométriques. Le cycle de vie des authenticateurs est essentiel pour la sécurité d'une application - si quelqu'un peut s'enregistrer lui-même sur un compte sans preuve d'identité, il ne peut guère faire confiance à l'affirmation de son identité. Pour les sites de médias sociaux comme Reddit, c'est tout à fait normal. Pour les systèmes bancaires, il est essentiel de mettre davantage l'accent sur l'enregistrement et la délivrance de justificatifs d'identité et de dispositifs pour assurer la sécurité de l'application.

Remarque : les mots de passe ne doivent pas avoir une durée de vie maximale ni être soumis à une rotation. Les mots de passe doivent être vérifiés et non remplacés régulièrement.

V2.3 Exigences relatives au cycle de vie des authenticateurs

#	Description	L1	L2	L3	CWE	NIST §
2.3.1	Vérifier que les mots de passe ou codes d'activation initiaux générés par le système DOIVENT être générés de manière aléatoire et sécurisée, DOIVENT comporter au moins 6 caractères, PEUVENT contenir des lettres et des chiffres, et expirent après une courte période de temps. Ces secrets initiaux ne doivent pas être autorisés à devenir le mot de passe à long terme.	✓	✓	✓	330	5.1.1.2 / A.3
2.3.2	Vérifiez que l'inscription et l'utilisation de dispositifs d'authentification fournis par l'abonné sont prises en charge, comme les jetons U2F ou FIDO.		✓	✓	308	6.1.3
2.3.3	Vérifier que les instructions de renouvellement sont envoyées suffisamment tôt pour renouveler les authenticateurs à durée déterminée.		✓	✓	287	6.1.4

V2.4 Exigences en matière de stockage des identifiants

Les architectes et les développeurs doivent se conformer à cette section lorsqu'ils construisent ou remanient du code. Cette section ne peut être entièrement vérifiée qu'en utilisant la révision du code source ou par des tests unitaires ou d'intégration sécurisés. Les tests d'intrusions ne peuvent pas identifier l'un de ces problèmes.

V2.4 Exigences en matière de stockage des identifiants

#	Description	L1	L2	L3	CWE	NIST §
2.4.1	Vérifiez que les mots de passe sont stockés sous une forme qui résiste aux attaques hors ligne. Les mots de passe DOIVENT être salés et hachés à l'aide d'une fonction approuvée de dérivation de clé ou de hachage de mot de passe à sens unique. Les fonctions de dérivation de clé et de hachage de mot de passe prennent un mot de passe, un sel et un facteur de coût en entrée pour générer un hachage de mot de passe. (C6)		✓	✓	916	5.1.1.2
2.4.2	Vérifiez que le sel a une longueur d'au moins 32 bits et qu'il est choisi arbitrairement pour minimiser les collisions de la valeur du sel parmi les hashes stockés. Pour chaque authentifiant, une valeur de sel unique et le hachage qui en résulte DOIVENT être stockés. (C6)		✓	✓	916	5.1.1.2
2.4.3	Vérifiez que si le PBKDF2 est utilisé, le nombre d'itérations DOIT être aussi important que les performances du serveur de vérification le permettent, généralement au moins 100 000 itérations. (C6)		✓	✓	916	5.1.1.2
2.4.4	Vérifiez que si bcrypt est utilisé, le facteur de travail DOIT être aussi important que les performances du serveur de vérification le permettent, généralement au moins 10. (C6)		✓	✓	916	5.1.1.2
2.4.5	Vérifier qu'une itération supplémentaire d'une fonction de dérivation clé est effectuée, en utilisant une valeur de sel qui est secrète et connue uniquement du vérificateur. Générer la valeur de sel en utilisant un générateur de bits aléatoires approuvé [SP 800-90Ar1] et fournir au moins la sécurité minimale spécifiée dans la dernière révision de la norme SP 800-131A. La valeur de sel secrète DOIT être stockée séparément des mots de passe hachés (par exemple, dans un dispositif spécialisé comme un module de sécurité matériel).		✓	✓	916	5.1.1.2

V2.5 Exigences en matière de récupération des identifiants

#	Description	L1	L2	L3	CWE	NIST §
2.5.1	Vérifiez qu'un secret d'activation initiale ou de récupération généré par le système n'est pas envoyé en clair à l'utilisateur. (C6)	✓	✓	✓	640	5.1.1.2
2.5.2	Vérifier que les indices de mot de passe ou l'authentification basée sur la connaissance (dites "questions secrètes") ne sont pas présents.	✓	✓	✓	640	5.1.1.2
2.5.3	Vérifiez que la récupération du mot de passe ne révèle en aucune façon le mot de passe actuel. (C6)	✓	✓	✓	640	5.1.1.2
2.5.4	Vérifiez que les comptes partagés ou par défaut ne sont pas présents (par exemple "root", "admin" ou "sa").	✓	✓	✓	16	5.1.1.2 / A.3
2.5.5	Vérifier que si un facteur d'authentification est modifié ou remplacé, l'utilisateur est informé de cet événement.	✓	✓	✓	304	6.1.2.3
2.5.6	Vérifier les mots de passe oubliés, et les autres chemins de récupération utilisent un mécanisme de récupération sécurisé, tel que TOTP ou autre soft token, mobile push, ou un autre mécanisme de récupération hors ligne. (C6)	✓	✓	✓	640	5.1.1.2
2.5.7	Vérifier qu'en cas de perte des facteurs d'authentification OTP ou multi-facteurs, la preuve d'identité est effectuée au même niveau que lors de l'inscription.		✓	✓	308	6.1.2.3

V2.6 Exigences relatives aux vérificateurs des secrets

Les tables d'authentifications secrètes sont des listes pré-générées de codes secrets, similaires aux numéros d'autorisation de transaction (TAN), aux codes de récupération des médias sociaux ou à une grille contenant un ensemble de valeurs aléatoires. Ils sont distribués aux utilisateurs en toute sécurité. Ces codes de recherche sont utilisés une fois, et une fois qu'ils sont tous utilisés, la liste secrète de recherche est jetée. Ce type d'authentificateur est considéré comme "quelque chose que vous avez "

#	Description	L1	L2	L3	CWE	NIST §
2.6.1	Vérifiez que les secrets de la table d'authentification ne peuvent être utilisés qu'une seule fois.		✓	✓	308	5.1.2.2
2.6.2	Vérifiez que les secrets de la table d'authentification ont un caractère aléatoire suffisant (112 bits d'entropie) ou, s'ils ont moins de 112 bits d'entropie, qu'ils sont salés avec un sel unique et aléatoire de 32 bits et hachés avec un hachage unidirectionnel approuvé.		✓	✓	330	5.1.2.2
2.6.3	Vérifiez que les secrets de la table d'authentification résistent aux attaques hors ligne, comme les valeurs prévisibles.		✓	✓	310	5.1.2.2

V2.7 Exigences relatives aux vérificateurs hors bande

Dans le passé, un vérificateur hors bande courant aurait été un courriel ou un SMS contenant un lien de réinitialisation de mot de passe. Les attaquants utilisent ce faible mécanisme pour réinitialiser des comptes qu'ils ne contrôlent pas encore, par exemple en prenant le compte de courrier électronique d'une personne et en réutilisant tout lien de réinitialisation découvert. Il existe de meilleurs moyens de gérer la vérification hors bande.

Les authentificateurs hors bande sécurisés sont des dispositifs physiques qui peuvent communiquer avec le vérificateur par un canal secondaire sécurisé. Les notifications "push" vers les appareils mobiles en sont des exemples. Ce type d'authentificateur est considéré comme "quelque chose que vous avez". Lorsqu'un utilisateur souhaite s'authentifier, l'application de vérification envoie un message à l'authentificateur hors bande via une connexion à l'authentificateur directement ou indirectement par le biais d'un service tiers. Le message contient un code d'authentification (généralement un nombre aléatoire de six chiffres ou un dialogue d'approbation). L'application de vérification attend de recevoir le code d'authentification par le canal principal et compare le hachage de la valeur reçue au hachage du code d'authentification original. En cas de correspondance, le vérificateur hors bande peut supposer que l'utilisateur s'est authentifié.

V2.7 Exigences relatives aux vérificateurs hors bande

#	Description	L1	L2	L3	CWE	NIST §
2.7.1	Vérifiez que les authenticateurs de texte en clair hors bande (NIST "restreint"), tels que les SMS ou le PSTN, ne sont pas proposés par défaut, et que des alternatives plus fortes, telles que les notifications "push", sont proposées en premier lieu.	✓	✓	✓	287	5.1.3.2
2.7.2	Vérifiez que le vérificateur hors bande expire les demandes d'authentification, les codes ou les jetons hors bande après 10 minutes.	✓	✓	✓	287	5.1.3.2
2.7.3	Vérifiez que les demandes d'authentification, codes ou jetons hors bande du vérificateur ne sont utilisables qu'une seule fois, et uniquement pour la demande d'authentification originale.	✓	✓	✓	287	5.1.3.2
2.7.4	Vérifier que l'authenticateur et le vérificateur hors bande communiquent sur un canal indépendant sécurisé.	✓	✓	✓	523	5.1.3.2
2.7.5	Vérifiez que le vérificateur hors bande ne conserve qu'une version hachée du code d'authentification.		✓	✓	256	5.1.3.2
2.7.6	Vérifiez que le code d'authentification initial est généré par un générateur de nombres aléatoires sécurisé, contenant au moins 20 bits d'entropie (en général, un nombre aléatoire de six chiffres est suffisant).		✓	✓	310	5.1.3.2

V2.8 Exigences relatives aux vérificateurs uniques à facteur unique ou à facteurs multiples

Les mots de passe à usage unique (OTP) sont des jetons physiques ou logiciels qui affichent un défi pseudo-aléatoire à usage unique en constante évolution. Ces dispositifs rendent le phishing (usurpation d'identité) difficile, mais pas impossible. Ce type d'authentifiant est considéré comme "quelque chose que vous avez". Les jetons multi-facteurs sont similaires aux OTP à facteur unique, mais nécessitent un code PIN valide, un déverrouillage biométrique, une insertion USB ou une valeur supplémentaire (comme les calculatrices de signature de transaction) à saisir pour créer l'OTP final.

V2.8 Exigences relatives aux vérificateurs uniques à facteur unique ou à facteurs multiples

#	Description	L1	L2	L3	CWE	NIST §
2.8.1	Vérifier que les OTP basées sur le temps ont une durée de vie définie avant d'expirer.	✓	✓	✓	613	5.1.4.2 / 5.1.5.2
2.8.2	Vérifier que les clés symétriques utilisées pour vérifier les OTP soumises sont hautement protégées, par exemple en utilisant un module de sécurité matériel ou un stockage de clés basé sur un système d'exploitation sécurisé.		✓	✓	320	5.1.4.2 / 5.1.5.2
2.8.3	Vérifier que des algorithmes cryptographiques approuvés sont utilisés dans la génération, dans la préparation et dans la vérification des OTP.		✓	✓	326	5.1.4.2 / 5.1.5.2
2.8.4	Vérifiez que l'OTP basé sur le temps ne peut être utilisé qu'une seule fois pendant la période de validité.		✓	✓	287	5.1.4.2 / 5.1.5.2
2.8.5	Vérifier que si un jeton OTP multi-facteur basé sur le temps est réutilisé pendant la période de validité, il est enregistré et rejeté avec des notifications sécurisées envoyées au détenteur du dispositif.		✓	✓	287	5.1.5.2
2.8.6	Vérifier que le générateur OTP physique à facteur unique peut être révoqué en cas de vol ou autre perte. S'assurer que la révocation est immédiatement effective pour toutes les sessions connectées, quel que soit le lieu.		✓	✓	613	5.2.1
2.8.7	Vérifiez que les authenticateurs biométriques sont limités à une utilisation en tant que facteurs secondaires en conjonction avec quelque chose que vous avez et quelque chose que vous connaissez.		o	✓	308	5.2.3

V2.9 Exigences relatives aux vérificateurs de logiciels et d'appareils cryptographiques

Les clés de sécurité cryptographiques sont des cartes à puce ou des clés FIDO, où l'utilisateur doit brancher le dispositif cryptographique à l'ordinateur pour compléter l'authentification. Les vérificateurs envoient un défi aux dispositifs ou logiciels cryptographiques, et le dispositif ou le logiciel calcule une réponse basée sur une clé cryptographique stockée en toute sécurité.

Les exigences relatives aux dispositifs et logiciels cryptographiques à facteur unique et aux dispositifs et logiciels cryptographiques à facteurs multiples sont les mêmes, car la vérification de l'authentificateur cryptographique prouve la possession du facteur d'authentification.

V2.9 Exigences relatives aux vérificateurs de logiciels et d'appareils cryptographiques

#	Description	L1	L2	L3	CWE	NIST §
2.9.1	Vérifier que les clés cryptographiques utilisées dans la vérification sont stockées de manière sûre et protégées contre la divulgation, par exemple en utilisant un TPM ou un HSM, ou un service OS qui peut utiliser ce stockage sécurisé.		✓	✓	320	5.1.7.2
2.9.2	Vérifiez que le nonce de défi est d'une longueur d'au moins 64 bits, et statistiquement unique ou non pendant la durée de vie du dispositif cryptographique.		✓	✓	330	5.1.7.2
2.9.3	Vérifier que des algorithmes cryptographiques approuvés sont utilisés dans la génération, la préparation et la vérification.		✓	✓	327	5.1.7.2

V2.10 Exigences d'authentification des services

Cette section n'est pas testable par tests d'intrusions, et n'a donc aucune exigence de L1. Toutefois, si elle est utilisée dans une architecture, un codage ou une révision de code sécurisé, le stockage de secrets en texte clair n'est en aucun cas acceptable.

#	Description	L1	L2	L3	CWE	NIST §
2.10.1	Vérifiez que les secrets d'intégration ne reposent pas sur des mots de passe immuables, tels que les clés API ou les comptes privilégiés partagés.		OS assisté	HSM	287	5.1.1.1
2.10.2	Vérifiez que si des mots de passe sont requis pour l'authentification des services, le compte de service utilisé n'est pas un identifiant par défaut. (par exemple, root/root ou admin/admin sont utilisés par défaut dans certains services lors de l'installation).		OS assisté	HSM	255	5.1.1.1
2.10.3	Vérifiez que les mots de passe sont stockés avec une protection suffisante pour empêcher les attaques de récupération hors ligne, y compris l'accès au système local.		OS assisté	HSM	522	5.1.1.1
2.10.4	Vérifier que les mots de passe, les intégrations avec les bases de données et les systèmes tiers, les seeds et les secrets internes, ainsi que les clés API sont gérés de manière sécurisée et ne sont pas inclus dans le code source ou stockés dans des dépôts de code source. Ce type de stockage DEVRAIT résister aux attaques hors ligne. L'utilisation d'un stockage de clés logiciel sécurisé (L1), d'un module de plate-forme de confiance (TPM) ou d'un module de sécurité matériel (L3) est recommandée pour le stockage des mots de passe.		OS assisté	HSM	798	

V2.10 Exigences d'authentification des services

#	Description	L1	L2	L3	CWE	NIST §
2.10.1	Vérifiez que les secrets d'intégration ne reposent pas sur des mots de passe immuables, tels que les clés API ou les comptes privilégiés partagés.		OS assisté	HSM	287	5.1.1.1
2.10.2	Vérifiez que si des mots de passe sont requis pour l'authentification des services, le compte de service utilisé n'est pas un identifiant par défaut. (par exemple, root/root ou admin/admin sont utilisés par défaut dans certains services lors de l'installation).		OS assisté	HSM	255	5.1.1.1
2.10.3	Vérifiez que les mots de passe sont stockés avec une protection suffisante pour empêcher les attaques de récupération hors ligne, y compris l'accès au système local.		OS assisté	HSM	522	5.1.1.1
2.10.4	Vérifier que les mots de passe, les intégrations avec les bases de données et les systèmes tiers, les seeds et les secrets internes, ainsi que les clés API sont gérés de manière sécurisée et ne sont pas inclus dans le code source ou stockés dans des dépôts de code source. Ce type de stockage DEVRAIT résister aux attaques hors ligne. L'utilisation d'un stockage de clés logiciel sécurisé (L1), d'un module de plate-forme de confiance (TPM) ou d'un module de sécurité matériel (L3) est recommandée pour le stockage des mots de passe.		OS assisté	HSM	798	

TP 1:



Thank You
For Your Attention